

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On February 21, 2022, the General Subdirectorate for Data Inspection (SGID) received for evaluation a notification of a personal data breach sent by the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S0611011, received on December 7, 2021, in which it informed the Spanish Agency for Data Protection of the following:

On December 2, 2021, it became aware of a security breach caused by a cyber incident that affected the confidentiality of personal data of approximately 60,000 users categorized as pre-university teaching staff of the Autonomous Community, in some cases with access credentials. Furthermore, they are aware of the sale of data related to applications and information managed by the Education Technologies Service.

(...).

They provide an IP address from where the attack occurred.

SECOND: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following aspects:

Preliminary assessment of the notification of the personal data breach in relation to the data provided by the data controller and other relevant aspects detected:

1. The breach approximately began on November 29, 2021. It was noted on December 2, 2021, and reported to this Agency on December 7, 2021.
2. (...).
3. The affected data includes: basic identifying data (NIF, NIE, or Passport), location, and contact information. NIF, Surnames, Name, Phone, Postal Address, Email, Gender, Retired, Disability (partial data). Passwords for 18 institutional accounts of Educarex (the educational portal of the Government of Extremadura) and passwords (...) of application management users (the number is not specified).
4. Volume of 60,000 users categorized as pre-university teaching staff of the Autonomous Community.
5. Communication to the affected parties pending decision.
6. They indicate the existence of an ongoing investigation and that they will inform the appropriate authorities.

There are no previous incidents related to security breaches in the information systems by this same data controller.

INVESTIGATED ENTITIES

During the present actions, the following entities have been investigated:

DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA with NIF S06110011 located at AV. VALHONDO, NUM 1 - 06800 MÉRIDA (BADAJOZ)

RESULT OF THE INVESTIGATIVE ACTIONS

On May 18, 2022, it was decided to request information from the data controller in line with the following lines of investigation:

- To know the possible use by third parties of the personal data obtained through the breach.
- To know the status of the possible communication of the incident to the affected parties.
- To know the risk analysis conducted and the preventive and reactive security measures.
- To know the result of the last (mandatory) audit in accordance with the National Security Scheme (ENS), which is mandatory for Public Administrations.
- To know the updated incident register.
- In the notification of the breach, it was indicated that among the affected data, there were partial data on the disability of individuals; clarification is requested at this point regarding what type of information

was stored in the leaked database.

On June 1, 2022, a response to the previous request was received, from which the following conclusions can be drawn:

1. They state that they are not aware of the use by third parties of the data that may have been obtained through the breach.
2. They state that they have analyzed the risk caused by the breach to the rights and freedoms of the affected parties, using tools and applications specific to the Administration of the Autonomous Community of Extremadura. Concluding the following:

“(…)”. Also providing the following statements:

(…).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/27

3. They affirm that for the activities of personal data processing affected by the breach, a prior and regulated Risk Analysis process has NOT been carried out, justifying this with the following text: “(…)”.
4. Regarding the security measures implemented prior to the breach, they confirm the following:

(…).

(…).

5. (…)

6. Regarding the reactive measures adopted after the incident, they affirm the following:

(…).

7. In relation to the copy of the report requested from the last audit in accordance with the ENS, they affirm that a process of audit for the indicated information system has NOT been carried out.

8. Regarding the clarification of the disability data leaked in the breach, they respond by indicating that the database only stored “A” or “B,” so it is coded information and had not been leaked.

Concerning the assertion made in the response to the previous section 2, during this investigation, the inspector decides to use the COMUNICA-BRECHA RGPD tool with the data provided to us in the breach notification, and the result is the following: “YOU SHOULD NOTIFY THE SECURITY BREACH TO THE AFFECTED PARTIES.” Specifically, the information used as input in this tool has been:

- Intentional incident, external and consequent of a cyber incident.
- Unauthorized persons or organizations have been able to access and extract data.
- The data was not encrypted.
- The affected individuals may encounter significant inconveniences, causing limited harm, which they may overcome despite some difficulties.
- There is no record of the materialization of any of the identified harms.
- The probability of materialization is low.
- The data is (basic, identification document, contact information, access credentials).
- There are no minors among the affected individuals, and the existence of vulnerable groups is unknown.
- The breach affects about 60,000 users categorized as pre-university teaching staff of the Autonomous Community and was detected on December 2, 2021, with an approximate start date of November 29, 2021.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/27

Regarding the assertion made in the response to the previous section 3, in which they affirm that they do NOT have a Risk Analysis for the activities of processing affected by the breach (and provide justification for this), it is necessary to refer to what is indicated in their own internal policy (...) in

section 7.2:

(...).

Thus, it is confirmed that, even according to their own Internal Privacy Policy, this analysis should have been carried out.

In relation to the security measures implemented prior to the breach, as stated in section 9 of the (...): Also regarding the ENS, and in relation to the response to the requirement provided in the previous section 7, in which they confirm that a process of audit in accordance with the provisions of the National Security Scheme for the information system affected by the breach has NOT been carried out, it is necessary to refer to what is indicated in Article 34 of RD 3/2010, which regulated the ENS at the time of the breach (recently repealed by Royal Decree 311/2022, of May 3, 2022), which specified that this audit was mandatory at least every two years, thus verifying compliance with the requirements of said Scheme. The current regulation of the ENS (RD 311/2022) also specifies this obligation in its Article 31. Specifically, according to the ENS, the object of this audit must cover the following points (among others):

- That a risk analysis has been carried out, with annual review and approval.
- That the protection recommendations described in Annex II (Security Measures) are complied with, depending on the application conditions of each case.

(...).

This type of attacks are well known and identifiable in security audits.

Finally, regarding the date of notification of the breach to this Agency, and according to the information extracted from the security incident report (attached in response to our requirement), it is confirmed that:

- The breach was detected on December 2, 2021, Thursday, around 18:51 hours. It is at this moment that knowledge of the personal data leak is obtained. The data was for sale on an internet forum with payment in bitcoins.
- On December 3, 2021, Friday, the incident report is finalized, already recording the log with the URL used in the attack, the details of the personal data extracted, and the structure of the affected tables.
- On this same day, the classification of the security incident, level of danger, and declaration of the data protection breach has already been determined, concluding the advisability of notifying the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/27

-

The breach was reported to this Agency on December 7, 2021, Tuesday. They justify the delay in notification by stating that “the 72-hour deadline expires outside of working hours, during the weekend, or on holidays.”

CONCLUSIONS

1.

According to the internal report prepared by the responsible party regarding the incident, the level of risk to the rights and freedoms of the affected individuals is assessed as HIGH, concluding that it is necessary to notify the AEPD, but that there is NO need to communicate the breach to the citizens. They indicate that they have used the COMUNICA-BRECHA RGPG tool, but have not obtained a conclusive result regarding this matter. During the course of this investigation, this tool was used with the data provided in the breach notification, resulting in the need to communicate the breach to the affected individuals.

2.

They do not have risk analyses for the personal data processing activities affected by the breach. They justify that, for all personal data processing activities that do not involve sensitive data, primarily identifying data, they are covered by the line of general controls applied at different levels within the organization, both in the organizational and operational and technical framework.

3.

There are preventive security measures in place, but they do not correspond to all the security measures provided in Annex II (Security Measures) of Royal Decree 3/2010, of January 8, 2010, which regulated the National Security Scheme at the time the breach occurred (recently repealed by Royal Decree 311/2022, of May 3, 2022). The non-compliance with some of these measures is acknowledged.

4.

They do not have a security audit in accordance with the provisions of the National Security Scheme for the indicated information system; this audit is mandatory according to the regulations governing this Scheme.

5.

Diligence and promptness are shown in the internal process of analysis and management of the incident; a very complete and detailed report of the incident is documented, and the support of the Information Security Officer (Data Protection and Information Security service) is sought to assess the level of danger of the breach. In this internal analysis process, contact is made with cybersecurity bodies in Spain, such as INCIBE and CCN CERT, and a complaint is also filed with the National Police Corps.

THIRD: On December 27, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, and for the alleged infringements of Articles 32 of the GDPR and 34 of the GDPR, classified in Article 83.4 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/27

The initiation agreement was sent, in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), via electronic notification, being received on December 28, 2022, as stated in the certificate included in the file.

FOURTH: Once the aforementioned initiation agreement was notified in accordance with the provisions established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the investigated entity submitted a written statement of allegations in which, in summary, it expressed that regarding the affected data, the impact and nature of the same do not correspond in all cases to natural persons and, in no case, to sensitive information, data of minors, financial data, etc., or any other data that could be used for fraudulent operations.

Regarding the number of IPs from which the attack occurred, in the notification of the personal data breach made to the Agency, a technical report was provided that specified dozens of IP addresses from which the attack had been carried out.

Concerning the chronology of the recorded events, it is indicated that since the possible data breach became known, contacts were established for incident management with the National Police Corps, INCIBE, and the National Cryptologic Center through the opening of the corresponding incident, and measures were adopted to eliminate the possible risk.

Furthermore, it states that there is no knowledge of the use by third parties of the data that, in this case, may have been obtained.

Regarding the risk analysis of the data breach, it is indicated that a new procedure for communicating personal data breaches will be developed to align -exactly- with the terminology and scales set out in the GDPR and LOPDGDD, as well as in the Guide for the Notification of Personal Data Breaches of that Agency and the WP250 (GT29) Guidelines on the Notification of Personal Data Security Breaches, in accordance with Regulation 2016/679.

It adds that the development of a new application for the Management of Privacy and Information Security in the Administration of the Autonomous Community of Extremadura is planned, which also

(...) and that work is currently ongoing in the corrective and adaptive maintenance of the development and complete review of the data processing activities involved in the information system, which has led to the implementation of a new development that corrects the vulnerabilities that caused the breach. Regarding the use of the COMUNICA-BRECHA GDPR tool and the results communicated in response to the request of May 18, 2022, and differences in the results with those provided in the notification of the initiation of sanctioning agreement of December 28, 2022, it is acknowledged that there are indeed differences that,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/27

as has been verified, arise from two variations in the parameters of use of said tool.

On the other hand, it is stated that, in the contract tendered and awarded at a general level for the management of privacy and information security, specific tasks for detecting technical vulnerabilities, external/internal attacks, pentesting, etc., have been incorporated specifically in the early stages of contract execution and within the risk analysis as tasks that help identify this issue.

It is emphasized that in the Administration of the Autonomous Community, the management of information security and data protection is conducted, although it is possible that there are failures in the implementation of controls and protective measures as has occurred in this case. These incidents are managed diligently to apply corrective measures to mitigate impact and those preventive measures that help improve, with the commitment to enhance all processes that may help prevent incidents like the one being analyzed.

In relation to the Legal Foundations and typification included in the Initiation Agreement, it is indicated that no sanctioning procedure should be initiated against the Ministry of Education and Employment – Junta de Extremadura, as none of the circumstances that occurred correspond to the assumptions of infractions regulated in the provisions that motivate the initiation agreement of the sanctioning procedure.

It is considered that there is no alleged infringement of Article 5.1.f) GDPR, since the management of information security and data protection carried out by that Administration is evident, despite the existence of failures that may facilitate the exploitation of some vulnerabilities that were detected and managed.

Based on the above, it is not considered that there is an alleged infringement of Article 32 GDPR, given that measures had been adopted, although some failed.

Likewise, the infringement of Article 34 GDPR is not considered, as none of the circumstances for communication to the interested parties are present. It is stated that the typification included in the agreement regarding the present case does not correspond with the reality of the processing carried out, since there is no knowledge of a requirement made by that Control Authority for communication to the interested parties regarding the incident reported to this Agency on December 7, 2021.

Attached to the report of allegations signed by the General Directorate of Innovation and Educational Inclusion is the response letter dated June 1, 2022, the analysis of the security incident of December 3, 2021, and the complaint filed with the National Police Commissioner on December 7, 2021.

FIFTH: On February 3, 2023, a resolution proposal was made, proposing:

<< That the Director of the Spanish Agency for Data Protection impose on the MINISTRY OF EDUCATION AND EMPLOYMENT - JUNTA DE EXTREMADURA, with NIF S06110011,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/27

- For a violation of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription in Article 72.1 a) of the

LOPDGDD, a warning sanction.

- For a violation of Article 32 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, qualified as serious for the purposes of prescription in Article 73 f) of the LOPDGDD, a warning sanction.
- For a violation of Article 34 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, qualified as serious for the purposes of prescription in Article 74 ñ) of the LOPDGDD, a warning sanction.
- And order the communication of the security breach to the affected parties under the conditions established in Article 34 of the GDPR, as well as the implementation of the necessary corrective measures to align its actions with personal data protection regulations, preventing similar incidents from occurring in the future.

The aforementioned proposal for resolution was sent, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), by electronic notification, having been received on February 6, 2023, as evidenced by the certificate in the file.

SIXTH: On February 20, 2023, the investigated entity submitted a written statement of allegations to the Proposal for Resolution, in which, in summary, it reiterates the content of the allegations expressed in the response to the initiation agreement of the sanctioning procedure, understanding that the facts on which the violations are based are sufficiently explained and reasoned, demonstrating diligent action on the part of that Department, since once the incidents occurred, they were reported to the National Police and communicated to this Data Protection Agency, sufficient reasons to consider that the violations have not been committed, and therefore, it should be exempted from the attributed responsibility.

Regarding the promptness of the actions and the alleged expiration of the procedure, it states that the prior actions should be understood as expired since the period between the date of notification and acknowledgment of receipt of the incident (December 7 and December 13, 2021, respectively) and the Agreement to initiate the Sanctioning Procedure (December 28, 2022) exceeds the 12-month period established by the LOPDGDD as the maximum duration for such actions.

Furthermore, it does not consider that there is an alleged violation of Article 5.1.f) of the GDPR, since the management of information security and data protection carried out is evident, despite the existence of failures that may facilitate the exploitation of some vulnerabilities that were detected and managed.

Based on the above, it is not considered that there is an alleged violation of Article 32 of the GDPR, referring to everything already stated in the allegations.

The violation of Article 34 of the GDPR is not considered, as the circumstances for communication to the interested parties do not exist. There is no knowledge of a requirement.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/27

formulated by that Control Authority for communication to the interested parties regarding the incident reported to that Agency on December 7, 2021, up to the Resolution Proposal of February 2023. The fact of ordering the communication of the breach to the affected parties now and at the time of issuing the Resolution Proposal undermines a possible infringement of Article 34 of the GDPR, classified according to the provisions of Article 83.4 of the GDPR, deemed serious for the purposes of prescription in Article 74 ñ) of the LOPDGDD, and this is because there is no prior requirement from that party to this Administration to carry out the communication to the interested parties.

Regarding the proposal to order the communication of the security breach to the affected parties under the conditions established in Article 34 GDPR, it states that:

- It is now, in 2023, in the notification of the resolution proposal of the sanctioning procedure that this

Control Authority makes to that Autonomous Administration, when it requests - for the first time - the communication to the interested parties of a data breach that occurred in 2021, when there is not even evidence of material risks to the interested parties arising from it and, in any case, this Administration does not share that such risk has the consideration of High according to the scale handled in the regulatory legislation.

- It should be weighed that this Administration detected and controlled the incident in less than a week, including the necessary communications to State Security Forces and Bodies, specialized Entities, and that Control Authority, having always been proactive in the decisions and actions taken regarding the adoption of appropriate technical and organizational measures to improve information security and the protection of personal data.

- This Administration understands, therefore, that such communication at this moment would generate social alarm and a lack of trust in this Administration, on the part of its own employees and citizens.

- The requirement for this Administration to communicate to the affected parties, once the deadline for carrying out the Preliminary Actions has been widely exceeded, would generate defenselessness in this Autonomous Administration in its capacity as an interested party in the Sanctioning Procedure and, what is even worse, a social alarm that does not correspond with the nature and characteristics of the violation, nor with the absence of evidence of materialization of risks arising from it.

Finally, it claims that it has carried out, and continues to carry out, the implementation of necessary corrective measures to adapt its actions to the personal data protection regulations, such as the development of a version of the concerned application that eliminates the vulnerabilities exploited in this breach. An ambitious plan has also been launched for the improvement of data protection and information security, through the awarding and formalization of a contract for the "definition, development, implementation, operation, and continuous improvement of the privacy and information security management system of the Administration of the Autonomous Community of Extremadura," expte. XXXXXXXXXX, being crucial this procedure to improve processes such as those that may have failed in this case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/27

In view of all the actions taken by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: On February 21, 2022, the General Subdirectorate for Data Inspection (SGID) received for its assessment a notification of a personal data breach sent by the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S0611011, concerning a cyber incident that affected the confidentiality of personal data of approximately 60,000 users categorized as pre-university teaching staff of the Autonomous Community, in some cases with access credentials. Furthermore, there is knowledge of the sale of data related to applications and information managed by the Educational Technologies Service.

SECOND: From the information provided, it follows (...).

THIRD: Basic, identifying data (NIF, NIE, or Passport), location, and contact information have been compromised. NIF, Surnames, Name, Phone, Postal Address, Email, Gender, Retired, Disability (partial data). Passwords for 18 institutional accounts of Educarex (the educational portal of the Government of Extremadura) and passwords (XXXXXXX) of application management users (the number is not specified).

Volume: 60,000 users categorized as pre-university teaching staff of the Autonomous Community.

FOURTH: The investigated entity has not communicated the security breach and its possible adverse effects to those affected.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU)

2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/27

The Department of Education and Employment of the Government of Extremadura, like any other public entity, is obliged to comply with Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data -GDPR-, and with Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights -LOPDGDD- concerning the processing of personal data it carries out, understanding personal data as "any information relating to an identified or identifiable natural person."

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, "processing" should be understood as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, alignment, combination, restriction, erasure or destruction."

In light of the above, the Department of Education and Employment of the Government of Extremadura provides a series of public services, for which it processes personal data of its employees and citizens. It carries out this activity in its capacity as data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR: "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States.

Article 4, paragraph 12 of the GDPR broadly defines "personal data breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed."

In this case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach that affected the confidentiality of personal data of approximately 60,000 users classified as pre-university teaching staff of the Autonomous Community, and in some cases, access credentials stored with a considered weak hash system, affecting basic identifying data (NIF, NIE, or Passport), location, and contact information. NIF, Surnames, Name, Phone, Postal Address, Email, Gender, Retired, Disability (partial data). Password of 18.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/27

Institutional accounts of Educarex and passwords (XXX) of application management users (number not specified).

According to GT29, a "Breach of confidentiality" occurs when there is an unauthorized or accidental disclosure of personal data, or access to such data.

It should be noted that the identification of a security breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of those responsible and in charge, as well as the security measures applied.

Within the principles of processing provided in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data security breach to the supervisory authority, as well as the communication to the data subject, respectively.

III

Claims Made Regarding the Initiation Agreement

In response to the claims presented by the investigated entity, the following should be noted:

The investigated entity alleges that there is no presumed infringement of Article 5.1.f) of the GDPR, as the management of information security and data protection carried out by that Administration is evident, despite the existence of failures that may facilitate the exploitation of some vulnerabilities that were detected and managed.

In this regard, it should be noted that in the case at hand, a security breach occurred due to a cyber incident that affected the confidentiality of personal data of approximately 60,000 users categorized as pre-university teaching staff of the Autonomous Community, with basic, identifying data (NIF, NIE, or Passport), location and contact information, NIF, surnames, name, phone number, postal address, email, sex, retirement status, disability (partial data), passwords of 18 institutional accounts of Educarex (the educational portal of the Junta de Extremadura), and passwords of application management users being affected. This, combined with the publication on the Internet of a meager advertisement for the sale of data, undoubtedly constitutes a violation of the confidentiality of personal data. What is relevant to understand the breach of confidentiality is that the information was found completely at the free disposal of unauthorized third parties. The fact that there is no record of subsequent use of the data does not negate the fact that unauthorized access occurred.

In this sense, it is important to note that the passwords of 18 institutional accounts of Educarex and the passwords of application management users were subject to a loss of confidentiality. In this regard, it should be pointed out that the loss of confidentiality of access credentials implies, in turn, the possibility of accessing multiple other personal data after accessing the applications.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/27

Therefore, it cannot be defended in any way that there is no infringement of Article 5.1.f) of the GDPR, since, due to the lack of adequate security measures, personal data was accessible.

The duty of confidentiality is essential in increasingly complex societies, where advances in technology place individuals in risk areas for the protection of fundamental rights, such as privacy or the right to data protection enshrined in Article 18.4 of the Spanish Constitution.

Indeed, this provision contains a "guarantee institute for the rights of citizens that is, in itself, a fundamental right or freedom, the right to freedom against potential assaults on the dignity and freedom of the person arising from the unlawful use of the mechanized processing of data" (Judgment of the Constitutional Court 292/2000, of 30/11).

This fundamental right to data protection seeks to guarantee individuals control over their personal data, its use, and destination, preventing situations that infringe upon the dignity of the person, that is, the power to safeguard their private life from unwanted publicity.

In the case at hand, it has been established that the claimed party has violated this duty of confidentiality concerning the affected personal data.

This information cannot be provided to third parties, except with the consent of the users or if there is a legal authorization that allows its communication, circumstances that do not occur in the present case. All of this constitutes an infringement of Article 5.1.f) of the GDPR by enabling, due to the absence of protection measures, third parties to access personal data contained in the database.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/27

In any case, in this matter, an obligation of result is imposed, which entails the requirement that the measures implemented must effectively prevent third parties from accessing the information. This need for special diligence in the custody of the information by the responsible party has been highlighted by the National Court in its Judgment of 11/12/2008 (appeal 36/08), in which it states the following:

“... the appellant is, by legal provision, a debtor of security in data matters, and therefore must provide an adequate and reasonable explanation of how the data ended up in a place where it is susceptible to recovery by third parties, being insufficient to merely demonstrate that a series of measures are adopted, as it is also responsible for ensuring that these are complied with and executed rigorously.” The entity under investigation also claims that the Administration of the Autonomous Community manages information security and data protection, although it is possible that there are failures in the implementation of controls and protective measures, as has happened in this case. These incidents are managed diligently to apply corrective measures to mitigate impact and those preventive measures that help improve.

In this regard, it should be noted that, as already indicated in the Initiation Agreement of the present sanctioning procedure, the security measures were not being complied with at the time of the events. In this sense, they did not have risk analyses for the activities of processing personal data affected by the breach nor a security audit in accordance with the provisions of the National Security Scheme for the indicated information system. This audit is mandatory according to the regulations governing this Scheme.

There were preventive security measures, but they did not correspond to all the security measures provided for in Annex II (Security Measures) of Royal Decree 3/2010, of January 8, 2010, which regulated the National Security Scheme at the time the breach occurred (recently repealed by Royal Decree 311/2022, of May 3, 2022). The non-compliance with some of these measures is acknowledged.

Therefore, it can be deduced from all of this a lack of due diligence both in complying with the established security measures, as well as in the supervision or verification of their observance and/or their suitability.

In this regard, it is noted that Article 32 of the GDPR is infringed both if the responsible party does not adopt the appropriate technical and organizational measures that guarantee the security of personal data, and if, once established, these measures are not observed.

It is understood that the security measures implemented were insufficient, susceptible of being improved; this is evidenced by the assertion of the responding party that the mechanisms are improvable and, in fact, some actions have already been related that have been carried out for their improvement, such as hiring specialized external support, among others.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/27

Lastly, regarding the infringement of Article 34 of the GDPR, as indicated in the Initiation Agreement of

this sanctioning procedure, during the investigation, the inspector used the COMUNICA-BRECHA RGPG tool, with the data provided in the breach notification, resulting in the need to communicate the breach to the affected individuals.

Specifically, the information used as input in this tool has been:

- Intentional incident, external and consequent of a cyber incident.
- Unauthorized persons or organizations have been able to access and extract data.
- The data was not encrypted.
- The affected individuals may face significant inconveniences, causing limited harm, which they may overcome despite some difficulties.
- There is no record of the materialization of any of the identified harms.
- The probability of materialization is low.
- The data includes (basic, identification document, contact, access credentials).
- There are no minors among the affected individuals, and the existence of vulnerable groups is unknown.
- The breach affects approximately 60,000 individuals, detected on December 2, 2021, with an approximate start date of November 29, 2021.

It is important to consider the serious consequences that the leakage of data from approximately 60,000 users belonging to the category of pre-university teaching staff of the Autonomous Community may have on the rights and freedoms of the affected individuals, such as their basic, identifying data (NIF, NIE or Passport), location and contact information, NIF, surnames, first name, phone number, postal address, email, sex, retirement status, disability (partial data), passwords for 18 institutional accounts of Educarex (the educational portal of the Junta de Extremadura) and passwords for application management users.

In this regard, the aforementioned Article 34 establishes that when it is likely that the breach of security of personal data entails a high risk to the rights and freedoms of natural persons, the data controller shall communicate it to the affected individuals without undue delay.

Consequently, the allegations must be dismissed, indicating that the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

IV

Allegations Raised to the Resolution Proposal

In response to the allegations presented by the investigated entity to the Resolution Proposal, the following should be noted:

Regarding the promptness of the actions and the alleged expiration of the procedure, it is stated that the prior actions should be understood as expired since between the date of notification and acknowledgment of receipt of the incident.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/27

(December 7 and December 13, 2021, respectively) and Agreement to Initiate the Sanctioning Procedure (December 28, 2022), the period during which the aforementioned actions are carried out would far exceed the 12-month period established by the LOPDGDD as the maximum duration for them.

The argument presented by the investigated entity regarding this issue in its allegations does not conform to the law.

In the present case, the computation of the twelve-month maximum duration of the preliminary actions AI/00120/2022 began on February 21, 2022, the date of the agreement to initiate them, so it is noted that from that date until the date of the agreement to initiate the present sanctioning procedure, that is, December 27, 2022, the twelve-month period indicated in Article 67 of the LOPDGDD has not elapsed. On the other hand, it should be noted that the expiration period of the present procedure, established at nine months, is computed from the date on which its initiation is agreed upon, making it

inappropriate to add any other period to that computation for the purpose of measuring the duration of the administrative file, such as the time of the preliminary investigation actions, or the time that elapses between the conclusion of those actions and the opening of the procedure, nor the time corresponding to the admission phase of the claims presented.

This has been repeatedly declared by our Supreme Court. In the Judgment of 21/10/2015, the Judgment of 26/12/2007 (appeal 1907/2005) is cited, which states the following:

"[...] the period of the procedure [...] is counted from the initiation of the sanctioning file, which obviously excludes from the computation the time of the reserved information;" "[...] the greater or lesser duration of the preliminary phase does not entail the expiration of the subsequent procedure." Also, in the Judgment of the Supreme Court of 13/10/2011 (appeal 3987/2008) that examines a ground for cassation related to the computation of the expiration period of the procedure, the following is declared:

"We cannot share the reasoning presented by the lower court to set a different starting point than that established by the Law, indicating as the initial date of the computation the day following the conclusion of the preliminary informative proceedings.

[...]

Well, once those preliminary actions have been carried out, the time it takes for the Administration to agree to initiate the procedure [...] may have the consequences that apply regarding the computation of the prescription (extinction of the right); but it cannot be taken into consideration for the purposes of expiration, since this figure aims to ensure that once the procedure is initiated, the Administration does not exceed the time limit it has to resolve. In the third ground of the appealed judgment, the lower court makes an interpretation of the norm that is not in accordance with the nature of the institution of expiration, since unlike prescription, which is a cause of extinction of the right or responsibility in question, expiration is a way of terminating the procedure due to the passage of the period established in the norm, so its appreciation

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/27

does not prevent, if the established period for the prescription of the action for the restoration of urban legality by the Administration has not elapsed, the initiation of a new procedure."

Regarding the statements made in relation to the infractions attributable to the investigated entity for the violation of Articles 5.1.f), 32, and 34 of the GDPR, which essentially reiterate the allegations already presented throughout the sanctioning procedure, it should be noted that all of them have already been analyzed and dismissed in the Legal Basis III of the Proposal for Resolution and are reproduced in the Legal Basis III of this Resolution.

With respect to the proposal to order the communication of the security breach to those affected under the conditions established in Article 34 GDPR, it is deemed appropriate to estimate the allegation considering the circumstances of the specific case and given the time elapsed since the incident occurred, due to the limited practical utility that it would have to now require that communication be made to those affected.

Regarding the corrective measures that the investigated entity claims to be implementing to adapt its actions to the personal data protection regulations, such as the development of a version of the concerned application that eliminates the vulnerabilities exploited in this breach and the launch of an ambitious plan for the improvement of data protection and information security, through the awarding and formalization of a contract for the "definition, development, implementation, operation, and continuous improvement of the privacy and information security management system of the Administration of the Autonomous Community of Extremadura," while reflecting positive conduct, does not alter the established facts.

However, this Agency positively values the adoption of new measures that result in greater security regarding the processing of personal data and that may prevent, in the future, incidents like the one that is the subject of this procedure.

Consequently, the allegations must be dismissed, noting that the arguments presented do not undermine the essential content of the infractions declared committed nor do they constitute sufficient justification or exculpation.

V

Article 5.1.f) of the GDPR

Article 5.1.f) of the GDPR establishes the following:

"Article 5 Principles relating to processing:

1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

In relation to this principle, Recital 39 of the aforementioned GDPR states:

"[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing."

The documentation in the file provides clear evidence that the investigated entity violated Article 5.1.f) of the GDPR, principles relating to processing, since as a result of the confidentiality breach, the personal data of 60,000 users categorized as pre-university teaching staff of the Autonomous Community, contained in the system, were improperly exposed to third parties, and in some cases affecting access credentials (...), violating the principles of integrity and confidentiality, both established in the aforementioned Article 5.1.f) of the GDPR.

Consequently, it is considered that the established facts constitute an infringement, attributable to the investigated entity, for violation of Article 5.1.f) of the GDPR.

VI

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the prescription period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/27

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VII

Article 32 of the GDPR

Article 32 of the GDPR establishes the following regarding the security of processing:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context,

and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

The facts revealed indicate a lack of technical and organizational measures, allowing the display of personal data of users, resulting in a lack of diligence by the controller, permitting unauthorized access by third parties.

In the specific case being examined, (...).

Therefore, it is considered that there is sufficient evidence regarding the absence of adequate security measures, such as pseudonymization, designed to effectively apply data protection principles, such as data minimization, and to integrate the necessary safeguards in the processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/27

On the other hand, they do not have risk analyses for the activities of processing personal data affected by the breach. They also do not have a security audit in accordance with the provisions of the National Security Scheme for the indicated information system. This audit is mandatory under the regulations governing this Scheme.

There are preventive security measures, but they do not correspond to all the security measures provided in Annex II (Security Measures) of Royal Decree 3/2010, of January 8, 2010, which regulated the National Security Scheme at the time the breach occurred (recently repealed by Royal Decree 311/2022, of May 3, 2022). The non-compliance with some of these measures is acknowledged.

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of the technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/27

authorized to such data, particularly susceptible to causing physical, material, or immaterial damages and losses.”

Recital 75 of the GDPR lists a series of factors or situations associated with risks to the guarantees of the rights and freedoms of the data subjects:

“The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial damages and losses, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health or data about sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, preferences or personal interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable persons, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

In this regard, searching the internet, for example, for the name, surname, ID number, or email address of any of the affected individuals may yield results that, when combined with those now accessed by third parties, allow access to other applications of the affected individuals or the creation of personality profiles, which may not have been consented to by their owner.

The responsibility of the respondent is determined by the lack of security measures, as they are responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure a level of security adequate to the risk to safeguard the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

Consequently, it is considered that the established facts constitute an infringement, attributable to the entity being claimed, for violation of Article 32 of the GDPR.

VIII

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for

the imposition of administrative fines” provides:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

22/27

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”
In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year limitation period:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

IX

Article 34 of the GDPR

Article 34 “Communication of a personal data breach to the data subject” of the GDPR establishes:

“1. When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall communicate the breach to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, letters b), c), and d).

1. The communication to the data subject referred to in paragraph 1 shall not be necessary if any of the following conditions are met:

a) the controller has implemented appropriate technical and organizational protection measures, and those measures have been applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person not authorized to access it, such as encryption;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/27

b) the data controller has taken further measures to ensure that the likelihood of a high risk to the rights and freedoms of the data subject referred to in paragraph 1 no longer exists;

c) it would involve a disproportionate effort. In this case, a public communication or a similar measure will be chosen to inform the data subjects effectively.

4. When the controller has not yet communicated the personal data breach to the data subject, the supervisory authority, after considering the likelihood that such a breach poses a high risk, may require the controller to do so or may decide that one of the conditions mentioned in paragraph 3 is met.”

In this case, according to the internal report that the controller prepares regarding the incident, the level of risk to the rights and freedoms of the affected individuals is assessed as HIGH, concluding that it is necessary to notify the AEPD, but that there is NO need to communicate the breach to the citizen. They indicate that they have used the COMUNICA-BRECHA RGPG tool, but have not obtained a conclusive result in this regard.

Well, during the investigation, the inspector used this tool with the data provided in the breach notification, resulting in the need to communicate the breach to the affected individuals.

Specifically, the information used as input in this tool has been:

- Intentional incident, external and consequent of a cyber incident.
- Unauthorized persons or organizations have been able to access and extract data.
- The data was not encrypted.
- The affected individuals may encounter significant inconveniences, causing limited harm, which they may overcome despite some difficulties.
- There is no record of the materialization of any of the identified harms.
- The probability of materialization is low.
- The data includes (basic, identification document, contact information, access credentials).
- There are no minors among the affected individuals, and the existence of vulnerable groups is unknown.
- The breach affects approximately 60,000 individuals, detected on December 2, 2021, with an approximate start date of November 29, 2021.

It is important to consider the serious consequences that the leakage of data from approximately 60,000 users belonging to the category of pre-university teaching staff of the Autonomous Community may have on the rights and freedoms of the affected individuals, such as their basic data, identification (NIF, NIE or Passport), location and contact information, NIF, surnames, name, telephone, postal address, email, sex, retirement status, disability (partial data), passwords for 18 institutional accounts of Educarex (the educational portal of the Junta de Extremadura) and passwords for application management users.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/27

In this regard, the aforementioned Article 34 establishes that when it is likely that a breach of personal data security poses a high risk to the rights and freedoms of natural persons, the data controller shall communicate it to the data subject without undue delay.

Consequently, it is considered that the established facts constitute an infringement attributable to the investigated entity for violation of Article 34 of the GDPR.

X

Classification of the infringement of Article 34 of the GDPR

The aforementioned infringement of Article 34 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42 and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 74 “Minor infringements” of the LOPDGDD indicates:

“Minor infringements shall be considered those of a merely formal nature referred to in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 and, in particular, the following:

“(...)”

ñ) The failure to communicate to the affected individual a breach of data security that poses a high risk to the rights and freedoms of the affected individuals, as required by Article 34 of Regulation (EU) 2016/679, unless the provisions of Article 73 s) of this organic law apply.

(...)"

XI

Sanction

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/27

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines can be imposed on authorities and public bodies established in that Member State."

Furthermore, Article 77 "Regime applicable to certain categories of data controllers or processors" of the LOPDGDD states the following:

"1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

(...)

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed.

The resolution shall be notified to the controller or processor, to the body to which they hierarchically depend, if applicable, and to the affected parties who qualify as interested parties, if applicable.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible officer and shall order publication in the Official State Gazette or the corresponding autonomous gazette.

4. The resolutions related to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities."

6. When the competent authority is the Spanish Agency for Data Protection, it shall publish on its website, with due separation, the resolutions related to the entities in paragraph 1 of this article, with explicit indication of the identity of the controller or processor that has committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions shall be subject to what its specific regulations provide."

In the present case, based on the solid evidence available according to the proven facts in this sanctioning procedure, it is deemed appropriate to sanction the investigated entity with a warning for the infringement of Article 5.1.f) of the GDPR, for the infringement of Article 32 of the GDPR, and for the infringement of Article 34 of the GDPR, due to the lack of diligence in implementing appropriate security measures resulting in a breach of the principle of confidentiality, as well as for failing to communicate to the affected parties a data security breach that poses a high risk to their rights and freedoms.

XI

Adoption of Measures

The text of the resolution establishes what the infringements committed have been and the facts that

have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO SANCTION with a WARNING the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S06110011, for an infringement of Article 5.1.f) of the GDPR, classified according to the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription in Article 72.1 a) of the LOPDGDD.

SECOND: TO SANCTION with a WARNING the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S06110011, for an infringement of Article 32 of the GDPR, classified according to the provisions of Article 83.4 of the GDPR, qualified as serious for the purposes of prescription in Article 73 f) of the LOPDGDD.

THIRD: TO SANCTION with a WARNING the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S06110011, for an infringement of Article 34 of the GDPR, classified according to the provisions of Article 83.4 of the GDPR, qualified as serious for the purposes of prescription in Article 74 ñ) of the LOPDGDD.

FOURTH: TO REQUIRE the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA, with NIF S06110011, to implement, within a period of three months, the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/27

corrective measures necessary to adapt its actions to the regulations on personal data protection, which prevent similar events from occurring in the future, as well as to inform this Agency within the same timeframe about the measures adopted.

FIFTH: NOTIFY this resolution to the DEPARTMENT OF EDUCATION AND EMPLOYMENT - GOVERNMENT OF EXTREMADURA.

SIXTH: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day

following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es